Individual Testing

1. Assignment & Accountability

Contributor / Member ID	Ola ayman shoukry abdelsalam
Type of vulnerable	File upload
Week / reporting period	Week1 25/10/2026
Target / environment	Juice

2. Objective, Scope & Preconditions

Objective: Perform reconnaissance of OWASP Juice Shop with focus on file-upload and image-input functionality, identify upload-related endpoints, and record validation areas for later authorized security testing.

3. Test Log

Date	Asset / Endpoint	Test case	Outcome	Evidence ID
25/10/2026	POST /file-upload	Map Complaint/Invoice upload route	Upload-related attack surface recorded; Upload Type/Size themes noted	R-01
25/10/2026	POST /profile/image/file	Map profile image file-upload route	Profile image file-upload attack surface recorded for validation	R-02
25/10/2026	POST /profile/image/url	Map profile image URL-input route	Related image-input attack surface recorded; not treated as direct file upload	R-03
25/10/2026	POST /rest/memories	Map memory/image submission route	Memory/image submission attack surface recorded; version-dependent	R-04

4. Finding Record (duplicate this section for each suspected/confirmed finding)

Finding ID / Title	RECON-01 – Complaint / Invoice File Upload Surface
Affected Asset / Endpoint	/file-upload
Method	POST
Severity	High for documented Upload Type lead; Medium for documented Upload Size lead
Classification	Improper Input Validation – CWE-20 (Upload Type / Upload Size themes)
Finding ID / Title	RECON-02 – Profile Image File Upload Surface
Affected Asset / Endpoint	/profile/image/file
Method	POST
Severity	Not rated – Recon / requires validation
Classification	Upload-related attack surface – classification not established by reviewed source
Finding ID / Title	RECON-03 – Profile Image URL Input Surface
Affected Asset / Endpoint	/profile/image/url
Method	POST
Severity	Not rated – Recon / requires validation
Classification	Image URL input / related functionality – not confirmed as direct file upload
Finding ID / Title	RECON-04 – Memory / Image Submission Surface
Affected Asset / Endpoint	/rest/memories
Method	POST
Severity	Not rated – Recon / requires validation
Classification	Upload-related / image submission attack surface – version-dependent

4.1 Summary

Reconnaissance identified four upload-related application surfaces in the reviewed OWASP Juice Shop references: /file-upload, /profile/image/file, /profile/image/url, and /rest/memories. The /file-upload route is associated with the Complaint/Invoice workflow; the other routes relate to profile-image and memory/image functionality. Official Juice Shop challenge material also identifies Upload Type and Upload Size as Improper Input Validation themes relevant to /file-upload. These entries are reconnaissance findings/attack surfaces and do not by themselves prove exploitability.

4.2 Preconditions

OWASP Juice Shop must be running and accessible. A standard authenticated user may be required for user-specific upload features. Recon uses application mapping, documentation/source review, and passive request inspection. Availability, authentication requirements, and request structure should be checked against the selected Juice Shop version.

4.3 Reproduction Steps

1. Review the OWASP Juice Shop application and upload-related project references.
2. Identify the Complaint/Invoice upload route: POST /file-upload (UI workflow: /#/complain).
3. Record the profile image file-upload route: POST /profile/image/file.
4. Record the profile image URL route: POST /profile/image/url; note that this is related image-input functionality rather than a direct local-file upload.
5. Record the memory/image submission route: POST /rest/memories.
6. Record each route as an upload-related reconnaissance attack surface.
7. Cross-reference /file-upload with the documented Upload Type and Upload Size challenge themes under Improper Input Validation.
8. Record endpoint behavior, authentication, request fields, file-type checks, size checks, and response behavior as items for later validation.
9. Stop at reconnaissance; do not claim exploitability unless separately validated.

4.4 Expected vs. Actual Result

Expected: Reconnaissance should identify upload-related functionality, endpoint paths, HTTP methods, access requirements, and validation points requiring later testing.

Actual: Four upload-related routes were recorded from the reviewed Juice Shop references: POST /file-upload, POST

/profile/image/file, POST /profile/image/url, and POST /rest/memories. File type and file size validation were additionally identified as priority themes for /file-upload. These are recon findings/candidate attack surfaces; exploitability was not established during this phase.

4.5 Impact & Limitations

Impact: Upload-related endpoints increase the application attack surface because uploaded or remotely referenced content must be validated and handled safely. The recon identifies where later validation should focus, but it does not demonstrate successful bypass, code execution, stored malicious content, or other exploit impact.

Limitations: This is reconnaissance. Endpoint behavior and security impact remain version-dependent and require separate authorized validation before any route is treated as a confirmed vulnerability.

4.6 Remediation Recommendation

For later validation and remediation, enforce server-side allowlisting of permitted file types, verify actual file content rather than relying only on the filename or client-supplied MIME type, enforce strict file-size limits on the server, generate safe server-side filenames, store uploads outside executable web paths where applicable, and log rejected or suspicious upload attempts. These controls should be verified during the vulnerability-assessment phase.

5. Evidence Register

Filename / location	Related finding	Sensitive data redacted?
Recon endpoint inventory / reviewed references	RECON-01 – /file-upload	Yes
Recon endpoint inventory / reviewed references	RECON-02 – /profile/image/file	Yes
Recon endpoint inventory / reviewed references	RECON-03 – /profile/image/url	Yes
Recon endpoint inventory / reviewed references	RECON-04 – /rest/memories	Yes